

Modèle de rapport d'audit MUSA

En-tête du rapport

RAPPORT D'AUDIT DE SÉCURITÉ APPLICATIVE : MUSA

Titre :

Référence : MUSA-AUDIT-[AAAA] - [NN] Version :

Application auditée : Niveau d'audit : ☐ 1 ☐ 2 ☐ 3

Période d'audit : Structure auditée :

Lead auditor : Visa :

Date de transmission : Statut : ☐ Provisoire ☐ Définitif

Classification : ☐ Confidentiel ☐ Strictement confidentiel

Section 1 : Résumé exécutif (2 pages max.)

Consigne : Cette section est rédigée pour la direction. Elle ne contient aucun terme technique. Elle présente les 3 forces, les 3 vulnérabilités critiques, les 5 métriques et la recommandation principale.

Métriques à reporter :

- ◆ Taux de conformité global : $TC = \dots \%$
- ◆ Taux de conformité OWASP N2 : $TC_{N2} = \dots \%$
- ◆ Score de risque moyen : $\bar{R} = \dots$
- ◆ Entropie globale : $H_{global} = \dots$
- ◆ Score de maturité global : $\dots \%$

Verdict général : ☐ Satisfaisant ☐ Acceptable avec réserves ☐ Insuffisant ☐ Critique

Section 2 : Contexte et périmètre (1–2 pages)

1. Description de l'organisation (SOLTEC) : mission, effectifs, position dans l'écosystème TIC
2. Description de l'application auditée (GIDOCEP) : version, technologie, utilisateurs
3. Périmètre inclus :
4. Périmètre exclus :
5. Niveau d'audit retenu et justification :
6. Contraintes et limitations :

Section 3 : Méthodologie (1–2 pages)

1. Méthode appliquée : MUSA (Méthode Unifiée d'Audit de Sécurité Applicative)
2. Standards de référence : ISO 27001:2022, OWASP ASVS v4.0.3, NIST SP 800-115, ISO 19011:2018, normes IIA
3. Outils utilisés : (liste d'outils effectivement utilisés)

-
4. Composition de l'équipe d'audit : (noms, fonctions, rôles)
 5. Période et modalités des tests : (dates, horaires, environnement)
 6. Entropie de Shannon : description de son usage pour la reproductibilité

Section 4 : Synthèse des résultats (2–3 pages)

Tableau de bord complet :

- ◆ Distribution des constats : Conformes / NC / Zone grise / NA
- ◆ Distribution des vulnérabilités par niveau de risque (Critique / Élevé / Modéré / Faible)
- ◆ Répartition par catégorie OWASP ASVS (graphique radar)
- ◆ Score de maturité par domaine (graphique toile d'araignée)
- ◆ Comparaison avec le cycle d'audit précédent (si applicable)
- ◆ Valeur de H_{global} et interprétation

Section 5 : Détail des vulnérabilités (10–20 pages)

Pour chaque vulnérabilité identifiée, utiliser le modèle de fiche ci-dessous :

Table I.1. Fiche de vulnérabilité normalisée MUSA

Champ	Contenu
Identifiant	TECH-001 / ORG-001
Titre	Description courte (ex. : Mots de passe en clair en base)
Catégorie OWASP	V2.1 / V5.3 / etc.
Contrôle ISO 27001	8.5 / 5.17 / etc.
Description	Description technique détaillée du problème
Preuve	Référence à la capture d'écran / log en annexe
Impact	Description de l'impact métier et sécurité
Probabilité (P)	1 / 2 / 3 / 4
Impact (I)	1 / 2 / 3 / 4
Score de risque ($R = P \times I$)	1 / 4 / 9 / 16
Entropie (H_i)	Valeur + interprétation
Recommandation	Action corrective précise et actionnable
Priorité	Critique / Élevé / Modéré / Faible
Échéance	48h / 2 semaines / 1 mois / Planifié
Responsable	Nom + fonction

Section 6 : Plan d'action (2–3 pages)

Tableau de synthèse de toutes les recommandations :

- ◆ Action corrective (une par ligne)
- ◆ Priorité (Critique / Élevé / Modéré / Faible)
- ◆ Échéance (date précise)
- ◆ Responsable (nom, fonction)
- ◆ Indicateur de résolution (comment vérifier que c'est fait)
- ◆ Statut (Planifié / En cours / Réalisé / Reporté)

Section 7 : Annexes du rapport

Liste des pièces jointes au rapport :

- ◆ Papiers de travail PT01 à PT05 (ou extraits significatifs)
- ◆ Captures d'écran des vulnérabilités prouvées
- ◆ Exports bruts des outils (SonarQube, OWASP ZAP, OpenVAS)
- ◆ Grilles d'entretiens renseignées
- ◆ PV de la réunion de lancement
- ◆ PV de la réunion de clôture
- ◆ Déclarations d'indépendance signées